

MTB Incident Scoping Report

Carin Madden
PNC CyberBootcamp 2026
September 10, 2026

Executive Summary

The investigation shows that the intrusion started on August 28, 2026, which is about four days earlier than the original Day 3 timeline showed. The investigation found that two hosts, MTB-WEB01 and MTB-FILE01, were compromised, while the other three hosts did not show evidence of this attack. There were also two unusually large outbound transfers, including approximately 2.88 MB from MTB-WEB01 and 9.92 MB from MTB-FILE01, which means data may have left the bank. The attacker was also able to move from the compromised web server to the internal file server using SSH access.

Revised Timeline

The revised start of the intrusion is August 28, 2026 at 01:52:17 UTC. The perimeter firewall log shows the external attacker address making an allowed connection to MTB-WEB01 on port 80 at this time. The log then shows hundreds of connections against the same host shortly afterward, which is consistent with scanning activity.

This means the attack began about four days earlier than the Day 3 timeline suggested. The disk evidence did not show the earlier activity because the local Apache logs had been affected by log rotation, while the perimeter firewall telemetry was stored separately and retained for 90 days.

Another important event happened on August 30 at 02:09:12 UTC, when MTB-WEB01 made an outbound connection to the attacker's infrastructure on port 8443. This shows that the September 2 compromise was not the attacker's first activity on this server.

The approximate dwell time from the first observed activity on August 28 at 01:52:17 until the SOC alert on September 2 at 09:47:12 was 5 days, 7 hours, 54 minutes, and 55 seconds.

Confirmed Compromised Hosts

MTB-WEB01: Confirmed, high confidence

MTB-WEB01 was the original compromised web server. Evidence includes communication with attacker infrastructure, a malicious root-owned process, persistence, a UID 0 backdoor account, and outbound network activity. The firewall records also show that this host communicated with the attacker before September 2.

MTB-FILE01: Confirmed, high confidence

MTB-FILE01 was also compromised. Its authentication log shows an accepted SSH public-key login for svc-backup originating from MTB-WEB01 at 02:52:14 on September 2. The account received UID 0 privileges, and shortly afterward the System Log Forwarder service was started.

Endpoint telemetry provides additional evidence because MTB-FILE01 had a root-owned process maintaining an established external connection. The firewall log also shows repeated outbound connections and a large outbound transfer from this host.

Therefore, 2 of the 5 server-segment hosts are confirmed compromised: MTB-WEB01 and MTB-FILE01.

Hosts Assessed as Clean

MTB-APP01 — No evidence of compromise

I checked its authentication activity for suspicious SSH access, the known attacker accounts and indicators, and its process/network telemetry. The authentication log only shows legitimate public-key logins from the known analyst workstations and failed attempts for an invalid oracle account from a different internal address.

MTB-DC01 — No evidence of compromise

I checked its authentication records for suspicious logins and its process for attacker behavior. The recorded logins are internal, and the telemetry shows normal Windows processes without suspicious external connections.

MTB-DVWA01 — No evidence of compromise

I checked its network behavior, processes, and external connection. Although MTB-DVWA01 makes regular connections every five minutes, its asset record confirms that the monitoring agent is approved, uses a 300-second check-in interval, and connects to an approved endpoint. Therefore, the regular traffic is legitimate monitoring activity rather than an attacker beacon.

Lateral Movement

The attacker initially gained access to MTB-WEB01 through vulnerability finding ID MTB-0001. This vulnerability allowed server path traversal which allowed the attacker to eventually obtain root-level control using vulnerability finding ID MTB-0003. This vulnerability allowed local privilege escalation. The Day 3 investigation found SSH access available on the compromised host..

The attacker then moved laterally from MTB-WEB01 to MTB-FILE01 using SSH public-key authentication. At 02:52:14 on September 2, MTB-FILE01 accepted a public-key login for svc-backup originating from MTB-WEB01. That account operated with UID 0 privileges, giving the attacker root-level access to the second system.

The path was therefore:

Initial web-server compromise → root privileges → SSH access/key → SSH lateral movement → MTB-FILE01 → UID 0 access → additional persistence/external communication.

Data at Risk

Two outbound transfers stand out because they are much larger than the normal traffic in the perimeter logs.

Host	Timestamp (UTC)	Bytes Out	Approx. MB
MTB-WEB01	Sept. 2, 02:38:02	2,884,416	2.88 MB
MTB-FILE01	Sept. 2, 05:12:19	9,917,722	9.92 MB

The first transfer came from MTB-WEB01, the DMZ customer portal, so information associated with the web application or customer portal may have been included. The second and much larger transfer came from MTB-FILE01, an internal file server, so files stored or accessible through that server may have been transferred. The egress records show that data left these hosts, but the evidence provided does not establish exactly what was contained in those transfers, so data exfiltration should be treated as suspected rather than claiming specific files were stolen.

Intelligence Gaps

There are still several things that cannot be confirmed with the current evidence. We do not know exactly what data was contained in the two large outbound transfers, so additional network records, packet captures if available, and examination of files accessed immediately before the transfers would help determine what actually left the bank.

We also cannot say that August 28 was definitely the attacker's absolute first activity; it is the earliest activity visible in the provided perimeter extract. Reviewing the full 90-day perimeter telemetry could determine whether the attacker interacted with the environment before August 28.

Finally, the available evidence supports assessing MTB-APP01, MTB-DC01, and MTB-DVWA01 as clean for the indicators and behaviors checked, but that does not prove that no malicious activity of any kind ever occurred on them. Continued review of authentication, endpoint, file-system, and network telemetry would provide greater confidence in the scope.

Google sheets where evidence lives and more documentation occurred:  Week 6 Day 4

Disclaimer: Chatgpt was used to make this report flow easier with wording and formatting.